

E-Commerce Payment Gateway - Data Model & Entity Relations

Confidential - Internal Use Only

Version 1.0

1. Core Entities

Entity: Merchant - Fields: merchant_id (UUID PK), business_name (VARCHAR 255 NOT NULL), registration_number (VARCHAR 50), country_code (CHAR 2), settlement_currency (CHAR 3), api_key_hash (VARCHAR 128), status (ENUM: pending, active, suspended), created_at (TIMESTAMP), kyc_verified_at (TIMESTAMP NULL).

Entity: PaymentIntent - Fields: payment_intent_id (UUID PK), merchant_id (UUID FK -> Merchant), amount (DECIMAL 12,2 NOT NULL), currency (CHAR 3 NOT NULL), status (ENUM: created, authorized, captured, settled, failed, refunded), client_secret (VARCHAR 64 UNIQUE), created_at (TIMESTAMP), updated_at (TIMESTAMP).

Entity: Transaction - Fields: transaction_id (UUID PK), payment_intent_id (UUID FK -> PaymentIntent), payment_token (VARCHAR 64), auth_code (VARCHAR 10 NULL), risk_score (SMALLINT NULL), processor_response (JSONB), card_last4 (CHAR 4), card_brand (VARCHAR 20), created_at (TIMESTAMP).

Entity: Refund - Fields: refund_id (UUID PK), transaction_id (UUID FK -> Transaction), amount (DECIMAL 12,2), reason (VARCHAR 50), status (ENUM: initiated, processing, completed, failed), initiated_by (UUID FK -> MerchantUser), created_at (TIMESTAMP), completed_at (TIMESTAMP NULL).

Entity: CardToken - Fields: token_id (UUID PK), merchant_id (UUID FK -> Merchant), card_fingerprint (VARCHAR 64 NOT NULL), card_last4 (CHAR 4), card_brand (VARCHAR 20), exp_month (SMALLINT), exp_year (SMALLINT), created_at (TIMESTAMP). Note: Stored in isolated PCI CDE segment.

Entity: Subscription - Fields: subscription_id (UUID PK), merchant_id (UUID FK), customer_token (VARCHAR 64 FK -> CardToken), plan_id (VARCHAR 50), billing_cycle (ENUM: daily, weekly, monthly, annual), status (ENUM: active, past_due, cancelled, paused), next_billing_date (DATE), created_at (TIMESTAMP).

2. Relationships

Merchant 1:N PaymentIntent - A merchant can have many payment intents.

PaymentIntent 1:1 Transaction - Each payment intent has one transaction record (the latest attempt).

Transaction 1:N Refund - A transaction can have multiple partial refunds (total <= original amount).

Merchant 1:N CardToken - A merchant can tokenize multiple cards for their customers.

Merchant 1:N Subscription - A merchant can have multiple active subscriptions.

Subscription N:1 CardToken - Each subscription is linked to a tokenized payment method.

3. Data Validation Rules

REQ-ECO-085: Payment amount must be positive and <= 999,999.99.

REQ-ECO-086: Currency code must be a valid ISO 4217 code within the supported list.

REQ-ECO-087: Refund amounts must sum to <= original transaction amount for the given transaction.

REQ-ECO-088: Card expiry must be in the future at time of tokenization.

REQ-ECO-089: Merchant API key must be unique and generated using cryptographically secure random bytes (32 bytes, base64-encoded).

4. Data Retention & Archival

REQ-ECO-090: Transaction records must be retained for 7 years per PCI DSS requirements.

REQ-ECO-091: Archived records older than 13 months move to cold storage (AWS S3 Glacier) with metadata index in DynamoDB.

REQ-ECO-092: Card tokens must be deleted within 72 hours of merchant account closure.

REQ-ECO-093: Audit logs are append-only and stored in Elasticsearch with 90-day hot tier and 7-year cold tier.